Cabin Pressure

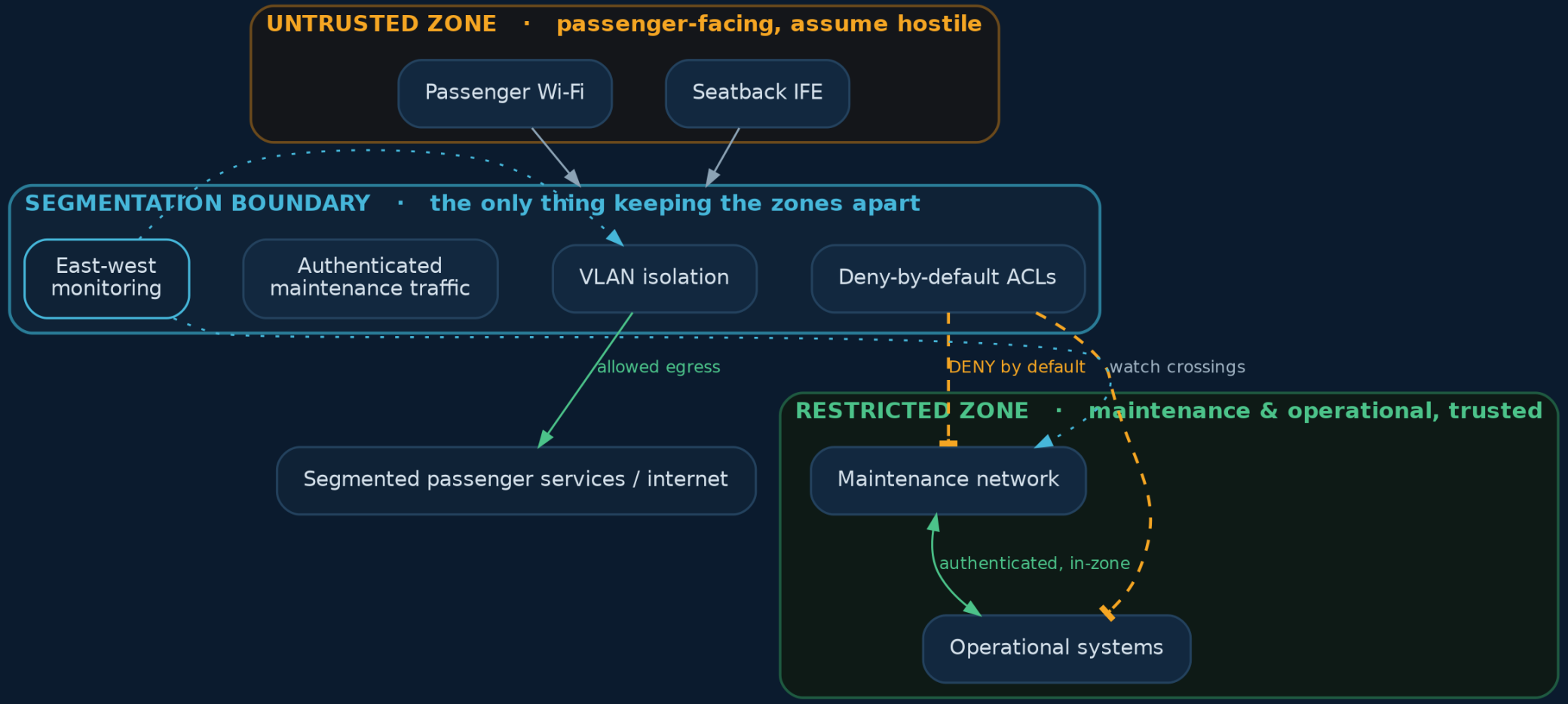
Boeing 787 cabin network segmentation: research, coordinated disclosure, and detection

Jack Sessions · DefCamp, Bucharest

THE THREAT MODEL

Segmentation is a safety boundary

Passenger Wi-Fi and IFE share the cabin network with maintenance and operational systems. The boundary between the untrusted and restricted zones is the whole game.



THE RESEARCH

What we set out to test

- Reverse-engineered the documented cabin network architecture of the Boeing 787
- Studied the cabin switching platform (HP ProCurve) and its segmentation configuration
- Assessed whether the isolation between passenger and restricted domains holds under real conditions
- Built a lab replica so all testing happened off any live aircraft (see next slides)

Scope discipline: every test was performed in a lab, under a coordinated-disclosure agreement. No testing was performed on an in-service aircraft.

FINDINGS

What we found

Isolation between the passenger and restricted domains was not absolute. The weaknesses fall into three classes:

VLAN segmentation integrity

Segmentation that can be undermined by tagging and trunking behaviour

ACL enforcement gaps

Access controls that do not fully constrain cross-domain traffic

Implicit trust of maintenance traffic

Traffic trusted by network position rather than authenticated

! **Exploit chain and configuration specifics are responsibly withheld pending remediation. This talk covers the impact, the disclosure, and the defence, not a reproduction recipe.**

COORDINATED DISCLOSURE

Handled under ISO/IEC 29147



Findings mapped to aviation cybersecurity standards DO-326A / ED-202A throughout.

STANDARDS

Mapping to DO-326A / ED-202A

The airworthiness security process gives a shared language for turning a finding into a fix. Each weakness was framed in its terms:

Security scope	Cabin network as a security perimeter between trust domains
Threat condition	Cross-domain traversal from passenger to restricted networks
Security measure	Enforced segmentation, authenticated maintenance traffic, monitoring
Effectiveness	Assessed against the real configuration, not the design intent

SAFE BY CONSTRUCTION

A lab, never a live aircraft

- Cabin network topology replicated in Proxmox and GNS3
- Segmentation, switching, and domain boundaries reproduced faithfully
- All assessment ran against the replica, on hardware we owned
- Topology files can be shared so defenders can study the same environment safely

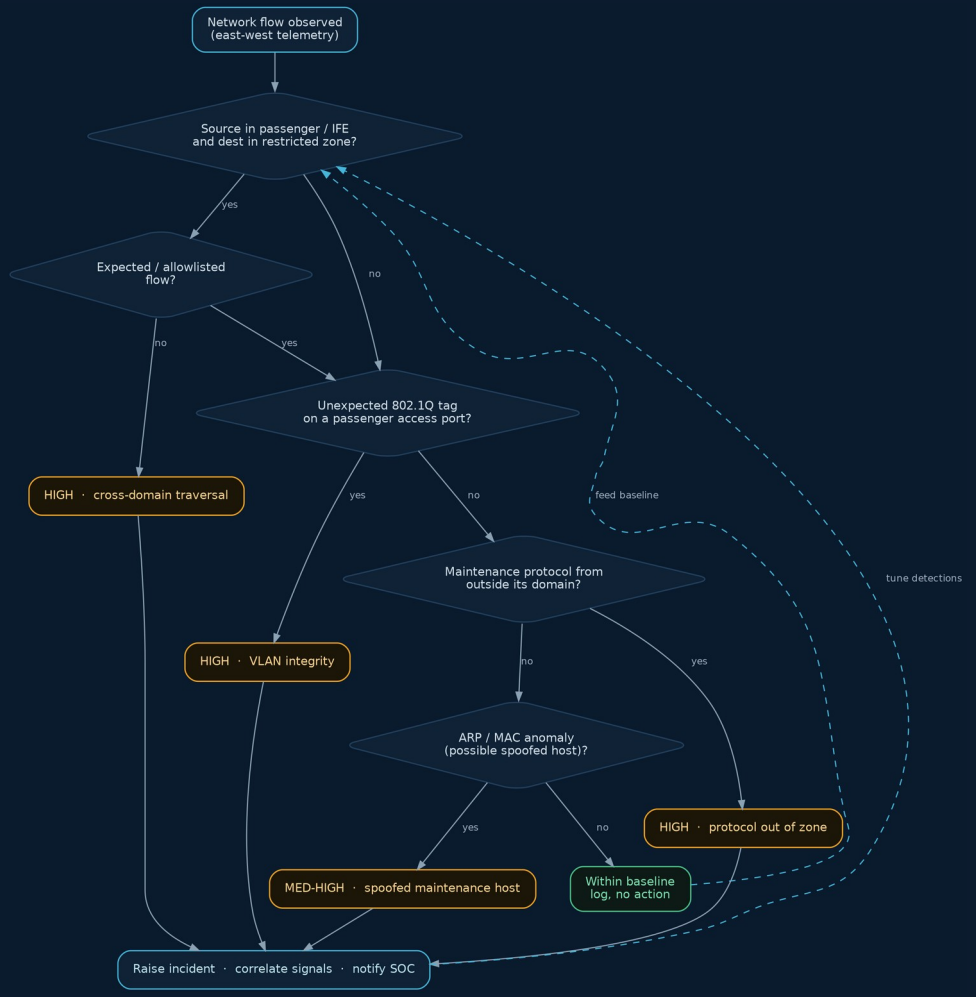
Why a replica

It lets the research be reproducible and reviewable without ever touching a system that flies.

Reproducible.
Reviewable.
Grounded.

DEFENCE

Detecting the lateral movement



This class of traversal is noisy if you watch the right east-west flows. Each observed conversation is triaged by one signal at a time.

- Cross-domain source and destination
- Unexpected 802.1Q tag on an access port
- Maintenance protocol from outside its domain
- ARP or MAC anomaly, a spoofed host
- New inter-domain talker vs. baseline

Ships as Sigma and YARA-L rules. Logic only, not a reproduction recipe.

HARDENING

What operators and integrators can do

Enforce the boundary

- Deny-by-default ACLs between trust domains
- Disable dynamic VLAN and trunk negotiation on passenger-facing ports

Stop trusting position

- Authenticate maintenance traffic, do not trust by network location
- Segment at both layer 2 and layer 3

Prove it stays true

- Continuously validate config against a known-good baseline
- Deploy the east-west detections from the previous slide

TAKEAWAYS

What to carry off the plane

1

Position is not trust

Segmentation must be enforced and monitored, never assumed from a diagram.

2

Disclosure works

Standards plus CERTs turned a safety-critical finding into a remediation process.

3

Detection ships today

East-west telemetry and Sigma / YARA-L catch this class of lateral movement now.

Coordinated disclosure completed under ISO/IEC 29147. Exploit specifics withheld pending remediation. · *Jack Sessions*